

CONFIDENCIAL - USO INTERNO RESTRINGIDO - SOC / CISO

INFORME TÉCNICO FINAL

RESPUESTA A INCIDENTES DE SEGURIDAD (LIVE INCIDENT RESPONSE)
Análisis Forense y Plan Propuesto de Remediación



Servidor Objetivo: 4geeks-server (10.0.2.8)

Fecha: 26 de septiembre de 2026

Elaborado por: Equipo Azul (Blue Team / CSIRT)

Estado: SISTEMA INTACTO (Intervención restringida)

INTRODUCCIÓN	3
ALCANCE	4
1. Revisión del incidente desde el servidor activo	5
2. Vulnerabilidades detectadas y a corregir.	6
Compromiso de Cuentas y Acceso Inicial	6
Mecanismos de Persistencia y Exfiltración Masiva	6
Demostración Forense de Inocencia (Usuario 'reports')	6
Timeline del Ataque (21 de junio al 5 de julio de 2025)	6
3. Acciones de contención, erradicación y recuperación aplicables.	8
Fase 1: Contención	8
Fase 2: Erradicación	8
Fase 3: Recuperación y Medidas Críticas	8
4. Recomendaciones para fortalecer el sistema y evitar futuras intrusiones.	9
5. Capturas justificadas de comandos clave y hallazgos técnicos	10

INTRODUCCIÓN

Este informe documenta la respuesta de un incidente de seguridad crítico en el servidor 4geeks-server. La investigación confirma una brecha de seguridad positiva mediante el compromiso de credenciales administrativas, lo que permitió a un atacante establecer persistencia de largo plazo y ejecutar una campaña de exfiltración de datos altamente sensible. La gravedad de este incidente es extrema: la infraestructura de 4Geeks ha estado expuesta y los hashes de contraseñas de todos los usuarios fueron comprometidos repetidamente. Este documento es vital para la toma de decisiones estratégicas respecto a la recuperación de la confianza en la identidad digital de la organización.

ALCANCES

- Alcance del estudio:

El sistema se mantiene en su estado original tras el triaje forense. Siguiendo órdenes directas, no se ha aplicado ninguna medida de remediación, eliminación de procesos o modificación de archivos. El servidor continúa en un estado vulnerable y comprometido hasta recibir autorización expresa para iniciar la fase de erradicación. La presente investigación se fundamenta en la recolección de evidencia volátil y el análisis de logs persistentes bajo una metodología de triaje en vivo rigurosa.

- Alcance del documento:

Este informe abarca exclusivamente el diagnóstico y análisis forense realizado en vivo sobre el servidor **4geeks-server** (`10.0.2.8`) con fecha de corte al **5 de julio de 2025**, mediante la ejecución remota de 23 comandos de triaje vía SSH con el usuario `sysadmin`. Incluye la reconstrucción de la cadena de ataque, la detección del usuario no autorizado `hacker` (UID 1002), la evidencia de exfiltración del archivo de sistema donde se guardan los usuarios creados y sus permisos hacia la IP C2 (`192.168.1.100:8080`) y la demostración forense de que el usuario `reports` no fue cómplice, al probarse la inyección artificial de su historial `.bash_history`. En cumplimiento estricto con la restricción de no modificar el sistema activo hasta nuevo aviso, el servidor se mantiene intacto; por ello, las acciones de contención, erradicación y fortalecimiento se presentan únicamente en clave de propuesta técnica sujeta a aprobación.

RESUMEN EJECUTIVO

El servidor fue comprometido por un **atacante externo** que logró ingresar tras adivinar la contraseña de la cuenta de administración (`sysadmin`) mediante fuerza bruta. Esta intrusión fue posible debido a **falta de previsiones en seguridad de red y puertos a la hora de configurar el equipo**, como el uso de contraseñas débiles y la falta de restricciones en el acceso remoto. Una vez dentro, el intruso creó una cuenta no autorizada y programó el envío automático de las contraseñas del sistema a un servidor externo cada 15 minutos. Para desviar la atención, intentó incriminar al usuario `reports` sembrando evidencia falsa, aunque la investigación demostró que este empleado es **totalmente inocente**.

Al **5 de julio de 2025**, el servidor permanece **intacto y sin modificaciones** en cumplimiento con la restricción de no intervenir el equipo activo. Nuestra propuesta para cuando se autorice la acción incluye bloquear los accesos del atacante, eliminar la cuenta falsa y sus scripts, cambiar todas las contraseñas del sistema y reforzar la seguridad general.

1.Revisión del incidente desde el servidor activo

La fase de triaje en vivo es el primer paso crítico en nuestra respuesta; permite capturar el estado actual de la memoria y la red antes de que cualquier evidencia volátil sea alterada por la actividad del atacante o por el reinicio del sistema. Tras ejecutar y analizar los comandos uptime, free y top, la carga del sistema se muestra inusualmente baja. Con una memoria total de **3.8Gi** , el sistema solo utiliza **220Mi** , manteniendo **3.3Gi libres** . Este estado de inactividad operativa permite descartar la presencia de minería de criptomonedas o ataques de denegación de servicio (DoS) originados desde este nodo. El servidor no está siendo utilizado por su capacidad de cómputo, sino como un punto de apoyo estratégico para el robo de información. La superficie de ataque identificada revela servicios críticos expuestos: HTTP (80), FTP (21) y SSH (22). El análisis de red confirma que el servidor opera bajo la IP 10.0.2.8. Un hallazgo estratégico positivo es la integridad de los servicios de **Wazuh** (wazuh-agentd, wazuh-syscheckd). Estos agentes no están configurados, pero a futuro, podrían permitir el registro de parte de la actividad maliciosa, lo que facilitará una futura implementación de monitoreo de integridad de archivos (FIM). La correlación de estos datos iniciales nos dirige hacia un análisis profundo de la persistencia técnica establecida por el atacante.

2. Vulnerabilidades detectadas y a corregir.

La reconstrucción analítica del ataque confirma que no estamos ante un intento de intrusión, sino ante un compromiso total de privilegios. La presente metodología utiliza un archivo .sh, de creación interna y desde la computadora de consultoría de ciberseguridad para ejecutar comandos de consulta de estados mayormente y documentarlos en diferentes archivos .txt que estarán disponibles en el link de Git hub ([documentos anexos](#)) y disponibles a petición en cualquier momento para la consideración de los pasos siguientes. Estos archivos serán citados regularmente en este informe

Compromiso de Cuentas y Acceso Inicial

La correlación de logs en 15ssh_failed_pass.txt es irrefutable: el **21 de junio a las 19:38:47**, el atacante desde la IP **192.168.1.50** logró un acceso exitoso al sistema tras un ataque de fuerza bruta. El registro indica: Accepted password for sysadmin from 192.168.1.50. Este compromiso de la cuenta sysadmin otorgó al atacante la plataforma necesaria para escalar privilegios y plantar mecanismos de persistencia. Se ha confirmado la creación de una cuenta no autorizada denominada **'hacker' (UID 1002)** con acceso a /bin/bash. A diferencia de las cuentas de servicio legítimas que carecen de shell, esta cuenta proporciona un acceso redundante al atacante.

Mecanismos de Persistencia y Exfiltración Masiva

El hallazgo más crítico es el establecimiento de una tarea programada maliciosa en /etc/cron.d/sys-maintenance. Este archivo invoca el script /usr/local/bin/backup2.sh con privilegios de root.

- **Frecuencia:** Ejecución cada 15 minutos.
- **Acción:** Exfiltración del archivo /etc/shadow hacia el servidor C2 en **192.168.1.100:8080**.
- **Impacto:** Dado que el sistema estuvo comprometido durante 14 días (336 horas), se calcula que el archivo de hashes de contraseñas fue exfiltrado aproximadamente **1,344 veces**. Esto garantiza que el atacante posee copias actualizadas de todas las credenciales del servidor.

Demostración Forense de Inocencia (Usuario 'reports')

La investigación ha identificado un intento deliberado de incriminar al usuario reports. El análisis del .bash_history de dicho usuario muestra el uso de sudo tee -a para plantar archivos sospechosos (chat.txt, install.sh, backup.log). La naturaleza de estos comandos es inconsistente con el perfil del usuario y el rastro técnico confirma que fueron inyectados para desviar la atención de la cuenta sysadmin comprometida y del script de persistencia real. Los hallazgos anteriores permiten establecer una línea de tiempo inequívoca del compromiso.

Timeline del Ataque (21 de junio al 5 de julio de 2025)

La reconstrucción cronológica determina un "dwell time" de 14 días, lo que representa una ventana de exposición crítica para la organización.

- **21 de Junio, 19:38:20:** Inicio de fuerza bruta desde la IP 192.168.1.50 contra el usuario root.
- **21 de Junio, 19:38:47: Brecha Exitosa.** La IP 192.168.1.50 accede como sysadmin. Se inicia el despliegue de persistencia.
- **23 de Junio, 15:26 - 15:29:** Segunda fase de actividad hostil. La IP 192.168.1.103 ejecuta fuerza bruta masiva contra múltiples usuarios ('admin', 'test', 'hacker'). Se detecta la manipulación de sesiones para incriminar al usuario reports.
- **5 de Julio:** Ejecución del triaje técnico y finalización del diagnóstico.

3. Acciones de contención, erradicación y recuperación aplicables.

Este plan es una recomendación estratégica de ejecución inmediata una vez autorizada la intervención. Su objetivo es la erradicación total del atacante y la restauración de la postura de seguridad.

Fase 1: Contención

- Bloqueo inmediato en firewall (capa 3 y 4) de las IPs atacantes: 192.168.1.103, 192.168.1.50 y el C2 de exfiltración 192.168.1.100.

Fase 2: Erradicación

- Eliminación del usuario hacker (UID 1002) y su directorio home.
- Borrado del archivo de persistencia `/etc/cron.d/sys-maintenance` y el script malicioso `/usr/local/bin/backup2.sh`.
- Auditoría de todos los binarios en `/usr/local/bin/` para descartar puertas traseras adicionales.

Fase 3: Recuperación y Medidas Críticas

- **Rotación de Credenciales Infraestructura-wide:** Debido a la exfiltración masiva de `/etc/shadow` (1,344 veces), es obligatorio el cambio de contraseñas de **todas** las cuentas del sistema y de cualquier otro sistema donde se reutilicen credenciales de 4Geeks.
- Saneamiento del `.bash_history` del usuario `reports` para restaurar su integridad forense. Se reitera que ninguna de estas acciones se ha ejecutado debido a las restricciones operativas vigentes descritas en el alcance de la actividad.

4.Recomendaciones para fortalecer el sistema y evitar futuras intrusiones.

Para evitar la recurrencia y pasar a una postura de defensa proactiva, se proponen las siguientes implementaciones técnicas:

- **SSH Hardening:** Deshabilitar totalmente la autenticación por contraseña (PasswordAuthentication no) y obligar el uso exclusivo de llaves criptográficas (RSA/Ed25519).
- **Implementación de Fail2ban:** Configuración de "jails" específicas para SSH y FTP para bloquear IPs tras 3 intentos fallidos.
- **Políticas de Iptables:** Aplicar el principio de mínimo privilegio, cerrando todos los puertos entrantes no esenciales y restringiendo las conexiones salientes a IPs conocidas.
- **Optimización de Wazuh:** Activar y tunear el módulo FIM (File Integrity Monitoring) para generar alertas de severidad alta ante cualquier modificación en /etc/ y /usr/local/bin/.Estas medidas reducirán la superficie de ataque y proporcionarán visibilidad en tiempo real ante futuros intentos de intrusión.
- **Robustecimiento de la cultura de prevención:** se denota varios puntos que califican la seguridad del sistema estudiado como un baja, lo que implica que es altamente aconsejable de un reforzamiento pedagógico de la cultura de prevención y un monitoreo del avance hacia una conciencia e importancia de estos asuntos.

CONCLUSIÓN

- **Confirmación del Incidente e Impacto** El análisis forense en vivo (**Live Incident Response**) realizado sobre el servidor **4geeks-server (IP 10.0.2.8)** con fecha de corte oficial al **5 de julio de 2025**, confirma un compromiso de seguridad originado el **21 de junio de 2025** mediante un ataque de fuerza bruta SSH contra la cuenta administrativa ``sysadmin`` desde la IP ``192.168.1.50``. A partir de esta intrusión, el atacante estableció mecanismos de persistencia crítica al crear el usuario no autorizado ``hacker`` (UID 1002) y configurar una tarea programada en ``/etc/cron.d/sys-maintenance``. Dicha regla ejecutó el script ``/usr/local/bin/backup2.sh`` con privilegios de ``root`` cada 15 minutos, resultando en la exfiltración continuada de credenciales y hashes del sistema hacia el servidor C2 (``192.168.1.100:8080``), contabilizando aproximadamente 1,344 eventos de exfiltración durante la ventana de exposición de 14 días.

- **Exoneración del Usuario Interno (reports)** La investigación forense descartó categóricamente cualquier responsabilidad o complicidad del usuario interno ``reports``. Se demostró técnicamente que la presencia de comandos en su historial ``.bash_history`` y la creación de archivos sospechosos en su directorio personal (``chat.txt``, ``install.sh`` y ``backup.log``) fueron inyectados y plantados sintéticamente por el atacante utilizando permisos de superusuario (``sudo tee -a``) con el propósito explícito de incriminarlo y desviar la atención.

- **Responsabilidad Institucional de Prevención** La responsabilidad de la prevención dentro de la organización recae en el equipo de administración de TI y gestión del servidor. La intrusión fue posible debido a vulnerabilidades operativas previsibles, principalmente el uso de una contraseña débil o adivinable en la cuenta ``sysadmin``, la falta de restricciones de red en el servicio SSH (puerto 22 expuesto sin limitación de IP) y la ausencia de herramientas de bloqueo automático frente a ataques de fuerza bruta (como ``Fail2ban``).

- **Estado del Servidor y Plan Propuesto** En cumplimiento estricto con la restricción de no realizar modificaciones o intervenciones en el servidor activo hasta nuevo aviso, el equipo se mantiene **intacto y en su estado original**. Por consiguiente, las acciones correctivas de contención (bloqueo de IP maliciosas en ``iptables``), erradicación (eliminación del usuario ``hacker`` y scripts maliciosos), recuperación (rotación obligatoria de contraseñas) y fortalecimiento (autenticación por claves SSH y monitoreo FIM con Wazuh) se presentan formalmente en clave de propuesta técnica sujeta a autorización ejecutiva para su posterior aplicación.

5. Capturas justificadas de comandos clave y hallazgos técnicos

Comando	Archivo de Fuente	Descripción del Hallazgo	Justificación Forense	Nº de imagen
cat /etc/passwd	hacker:x:1002:1002::/home/hacker:/bin/bash	Identificación de cuenta	no autorizada con shell interactivo	1
cat /etc/cron.d/sys-maintenance	*/15 * * * * root /usr/local/bin/backup2.sh	tarea recurrente programada	Confirmación de persistencia de nivel root cada 15 minutos	2
"grep ""Failed password""		Fallos SSH desde 192.168.1.50 y 192.168.1.103	Evidencia de ataques coordinados de fuerza bruta	3
ls -la /etc/cron.d		sys-maintenance con fecha del 23 de junio	Vinculación temporal del hallazgo con la ventana de intrusión	4

Identificación de Usuario Hacker (imagen 1):

```
sysadmin@4geeks-server:~$ cat /etc/passwd | grep -v "/usr/sbin/nologin"
root:x:0:0:root:/root:/bin/bash
sync:x:4:65534:sync:/bin:/bin/sync
tss:x:106:111:TPM software stack,,,:/var/lib/tpm:/bin/false
pollinate:x:110:1::/var/cache/pollinate:/bin/false
sysadmin:x:1000:1000:4geeks-server:/home/sysadmin:/bin/bash
lxd:x:998:100::/var/snap/lxd/common/lxd:/bin/false
reports:x:1001:1001:,,,:/home/reports:/bin/bash
wazuh:x:115:120::/var/ossec:/sbin/nologin
hacker:x:1002:1002::/home/hacker:/bin/bash
```

Configuración de Tarea Programada Maliciosa (imagen 2):

```
sysadmin@4geeks-server:~$ cat /etc/cron.d/*
30 3 * * 0 root test -e /run/systemd/system || SERVICE_MODE=1 /usr/lib/x86_64-linux-gnu/e2fsprogs/e2scrub_all_cron
10 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /sbin/e2scrub_all -A -r
0 0 * * * root /opt/scripts/logrotate.sh
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
35 0 * * * root test -x /etc/cron.daily/popularity-contest && /etc/cron.daily/popularity-contest --crond
*/15 * * * * root /usr/local/bin/backup2.sh
```

Registro de Intentos SSH Fallidos (imagen 3):

```
sysadmin@4geeks-server:~$ grep "Failed password" /var/log/auth.log
Jun 21 19:38:20 4geeks-server sshd[2001]: Failed password for root from 192.168.1.50 port 40230 ssh2
Jun 23 15:26:52 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 port 58760 ssh2
Jun 23 15:27:01 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 port 58760 ssh2
Jun 23 15:27:07 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 port 58760 ssh2
Jun 23 15:27:28 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103 port 49542 ssh2
Jun 23 15:27:32 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103 port 49542 ssh2
Jun 23 15:27:37 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103 port 49542 ssh2
Jun 23 15:28:33 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 ssh2
Jun 23 15:28:40 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 ssh2
Jun 23 15:29:15 4geeks-server sshd[1797]: Failed password for root from 192.168.1.103 port 47014 ssh2
Jun 23 15:29:21 4geeks-server sshd[1797]: Failed password for root from 192.168.1.103 port 47014 ssh2
```

Actividad programada recurrente (imagen 4):

```
sysadmin@4geeks-server:/etc/cron.d$ cat sys-maintenance
*/15 * * * * root /usr/local/bin/backup2.sh
```